

Étape 5 : Pentest Web du Serveur C2

Objectif : Identifier et exploiter les vulnérabilités de sécurité du serveur Command & Control.

Objectifs de l'Étape

À la fin de cette étape, vous devez :

-  Identifier au minimum **3 vulnérabilités web**
 -  Créer des Proof of Concepts (POC) fonctionnels
 -  Extraire des données sensibles de la base de données
 -  Documenter chaque vulnérabilité (type, impact, POC)
 -  Proposer des corrections
-

Fichiers Fournis

```
Etape5_PentestWeb/  
├── README.md           # Ce fichier  
├── c2_server/  
│   ├── app.py         # Serveur Flask vulnérable  
│   └── requirements.txt # Dépendances Python  
└── SOLUTIONS.md       # Solutions complètes
```

Instructions

1. Installation et Lancement du Serveur C2

1.1 Installer les Dépendances

```
cd Etape5_PentestWeb/c2_server/  
  
# Créer un environnement virtuel Python  
python3 -m venv venv  
  
# Activer l'environnement virtuel  
source venv/bin/activate  
  
# Installer Flask  
pip install -r requirements.txt  
  
# Ou directement  
pip install flask
```

Note : L'environnement virtuel doit rester activé pour toutes les commandes Python de cette étape.

1.2 Lancer le Serveur

```
# Assurez-vous que l'environnement virtuel est activé
# (vous devriez voir (venv) dans votre terminal)
python app.py
```

Vous devriez voir :

```
[*] Initialisation de la base de données...
[✓] Base de données initialisée avec des données de test

=====
  Serveur C2 (Command & Control) - Mode Pédagogique
=====

🌐 Serveur démarré sur http://localhost:5000

⚠ Ce serveur contient des vulnérabilités volontaires !
  À utiliser UNIQUEMENT pour l'apprentissage.
```

Laissez ce terminal ouvert et ouvrez un nouveau terminal pour les tests.

1.3 Tester l'Accès

Dans un navigateur, allez sur : <http://localhost:5000>

Ou avec `curl` :

```
curl http://localhost:5000
```

 **Question 1 :** Combien d'endpoints d'API sont listés ?

2. Reconnaissance des Endpoints

2.1 Lister Tous les Endpoints

Question 1bis : Listez tous les endpoints disponibles.

2.2 Tester Chaque Endpoint

 **Question 2** : Quels endpoints fonctionnent sans authentification ?

3. Identification des Vulnérabilités

VULNÉRABILITÉ 1 : Information Disclosure (Pas d'Authentification)

Description : Les endpoints sensibles ne requièrent aucune authentification.

Test : Accéder aux clés de chiffrement.

 **Question 3** : Combien de clés de chiffrement voyez-vous ?

 **Question 4** : Quelle est la clé exposée ?

Impact :

-  **CRITIQUE** : Un attaquant peut récupérer toutes les clés
- Les victimes peuvent déchiffrer leurs fichiers sans payer
- L'attaquant perd tout levier de rançon

POC (Proof of Concept) :

```
#!/bin/bash
# poc_info_disclosure.sh
echo "[*] Extraction des clés de chiffrement..."
curl -s ..... | python3 -m json.tool
```

VULNÉRABILITÉ 2 : IDOR (Insecure Direct Object Reference)

 **Question 5** : Pouvez-vous accéder aux données de toutes les victimes ?

VULNÉRABILITÉ 3 : SQL Injection

Description : L'endpoint `/api/search` est vulnérable à l'injection SQL.

 **Question 6** : Combien de résultats obtenez-vous avec l'injection ?

 **Question 7** : Pouvez-vous extraire les mots de passe admin ?

VULNÉRABILITÉ 4 : Hardcoded Secrets

Description : Des secrets sont hardcodés dans le code et exposés.

 **Question 8** : Quels secrets sont exposés ?

VULNÉRABILITÉ 5 : Manque de Rate Limiting

Description : Aucune limitation de requêtes, permettant le brute-force.

Test :

```
# Envoyer 100 requêtes rapidement
for i in {1..100}; do
    .....
done
```

4. Exploitation Avancée

4.1 Extraire Toutes les Données Sensibles

Créez un script `exploit_full.sh` :

```
#!/bin/bash
# exploit_full.sh - Extraction complète des données

TARGET="http://localhost:5000"

echo "=====
echo "  Exploitation Complète du Serveur C2"
echo "=====
echo ""

# 1. Liste des victimes

# 2. Extraction des clés

# 3. Config et secrets

# 4. SQLi - Admin users

echo ""
echo "[✓] Exploitation terminée !"
echo "  Fichiers créés: victims.json, keys.json, config.json,
admins.json"
```

Exécutez :

```
chmod +x exploit_full.sh
./exploit_full.sh
```

4.2 Analyser les Données Extraites



Question 9 : Combien de victimes uniques avez-vous extraites ?

5. Documentation des Vulnérabilités

5.1 Créer un Rapport de Pentest

Créez `pentest_report.md` :

```
# Rapport de Pentest - Serveur C2 Ransomware

## Informations Générales
- Cible : http://localhost:5000
- Date : [VOTRE DATE]
- Équipe : [VOTRE ÉQUIPE]

## Résumé Exécutif

### Vulnérabilités Identifiées
-  CRITIQUE :
-  ÉLEVÉ :
-  MOYEN :
### Impact Global
L'application est extrêmement vulnérable. Un attaquant peut :

---

##  Livrables de l'Étape 5

À remettre :
-  Fichier `pentest_report.md` avec au moins 3 vulnérabilités
-  Scripts POC fonctionnels (`.sh` ou `.py`)
-  Données extraites (victims.json, keys.json)
-  Réponses aux 9 questions
-  Recommandations de correction

---

##  Prochaine Étape

Avec toutes ces informations, vous pouvez maintenant finaliser votre rapport ! Passez à la phase de rédaction.

---

Bon pentest !  
```